Zabezpečený přenos dat

ISA - Laboratorní cvičení č.2

Prokotol ke cvičení

Vysoké učení technické v Brně

`https://github.com/nesfit/ISA/tree/master/lab2-zabezpeceni`

Jméno a příjmení:
Login:
Skupina (číslo nebo čas):
Datum:

1 Synchronizace času pomocí NTP

1.2 Nakonfigurované servery NTP:

M	S	Server (doménové jméno či IP adresa)	Stratum
^	*	tik.cesnet.cz	1
^	+	tak.cesnet.cz	1
^	+	ntp.nic.cz	1
^	-	time.cloudflare.com	3

Význam příznaku M: režim zdroje: `^` server, `=` peer, `#` lokální referenční hodiny
Význam příznaku S: stav: `*` vybraný (synchronizováno), `+` kombinovaný, `-` vyloučený, `?` nedostupný
Význam hodnoty Stratum: vzdálenost od ref. hodin (1 = přímo GPS/atomové, 2 = od stratum 1, ...)

2 Zabezpečený vzdálený přístup pomocí SSH

2.4 e) Algoritmus pro výměnu klíčů: `curve25519-sha256` (ECDH, Curve25519)
2.4 f) Uveďte, jaké zajímavé informace lze vyčíst z odchycené komunikace SSH:
Verze (banner `SSH-2.0-OpenSSH_8.0`), nabízené algoritmy (KEX, šifry, MAC), IP a porty; zbytek šifrován.
2.5 d) Vyplňte informace o vygenerovaných klíčích SSH:

	Význam	Název souboru	Přístupová práva
Veřejný klíč:	ověření identity; kopíruje se na server do `~/.ssh/authorized_keys`	`~/.ssh/id_rsa.pub`	`-rw-r--r--` (644)
Privátní klíč:	tajný, podepisuje přihlášení; chráněn heslem (passphrase), zůstává u klienta	`~/.ssh/id_rsa`	`-rw-------` (600)

2.6 c)-d) Vyplňte hesla požadovaná při přihlášení na vzdálený počítač:

	user	root
Heslo vyžadované při distribuci klíčů:	`user4lab` (heslo účtu)	`root4lab` (heslo účtu)
Heslo vyžadované při druhém přihlášení:	`fitvutisa` (ke klíči)	žádné (klíč bez hesla)

K čemu slouží soubor `.ssh/authorized_keys`?
Obsahuje veřejné klíče, jejichž držitelé (vlastníci odpovídajícího privátního klíče) se mohou k danému účtu přihlásit bez hesla účtu; musí mít práva 600.

Jak je možné přihlásit se na vzdálený počítač po neúspěšné autentizaci klíčem SSH?
Po 3 chybných pokusech o heslo ke klíči přejde SSH na další metodu (`ssh -v`: `Next authentication method: password`) a vyžádá heslo uživatele na vzdáleném počítači (`user4lab`).

2.7 d) Co se zobrazilo na výstup terminálu při přihlášení z účtu `root`?
Místo shellu se spustil vynucený příkaz `chronyc -n sources`: vypsaly se NTP zdroje souseda (IP adresy, bez DNS) a spojení se hned ukončilo (`Connection to hYY closed`).

2.8 c) Jak proběhlo opakované přihlášení na vzdálený počítač pomocí SSH?
Poprvé se heslo ke klíči zadalo agentovi (dialog gnome-keyring), agent si dešifrovaný klíč pamatuje, další přihlášení už proběhlo bez zadávání hesla.

3 Zabezpečení transportní vrstvy pomocí TLS

3.1 e) Uveďte, zda je možné vidět obsah odchycené komunikace HTTP a proč ano/ne?
Ano. HTTP přenáší data nešifrovaně, ve Wiresharku (Follow TCP Stream) je čitelný požadavek `GET / HTTP/1.0` i odpověď serveru (hlavičky i HTML).

3.2 c) Jak lze zjistit z odchycené komunikace TLS jméno cílového serveru?
Z rozšíření SNI (`server_name`) v paketu Client Hello, jméno `www.fit.vutbr.cz` je zde nešifrované; v TLS 1.2 také z certifikátu serveru (paket Certificate).

3.2 e) Je možné přečíst obsah komunikace a proč ano/ne?
Ne. Obsah je šifrovaný (TLS Application Data), vidět jsou jen IP adresy, porty, handshake (Client/Server Hello, certifikát) a délky záznamů.

3.2 g) Vyplňte informace o použité šifrovací sadě (cipher suite):

Šifrovací sada (ID, název):	`0xC030`, `TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384`
Algoritmus pro výměnu klíčů:	ECDHE (Elliptic Curve Diffie-Hellman Ephemeral)
Algoritmus pro zajištění autentizace:	RSA
Algoritmus pro šifrování přenosu:	AES 256 GCM
Délka šifrovacího klíče:	256 bitů
Hešovací algoritmus:	SHA384

3.3 b) Použitá šifrovací sada v prohlížeči (name): `TLS_AES_128_GCM_SHA256`, TLS 1.3

Informace o certifikátu:

Vydavatel certifikátu:	GEANT TLS RSA 1 (CA HARICA, pro CESNET/VUT)
Doba platnosti:	např. 06/2026 až 12/2026 (max. 200 dní)

3.3 c) Příklady důvěryhodných CA:
ISRG Root X1 (Let's Encrypt), DigiCert Global Root G2, USERTrust RSA Certification Authority, HARICA TLS RSA Root CA 2021, GlobalSign Root CA